

Setnayan — Records of Processing Activities (RoPA) / Data Inventory

DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization and NPC filing; not yet adopted. · 2026-07-05

The accountability record RA 10173 (Data Privacy Act of 2012) and its IRR require a Personal Information Controller (PIC) to maintain: a register of the Data Processing Systems (DPS) it operates. Each row below is **one DPS**. Sourced from 01_Contracts/Setnayan_Privacy_and_Security_Policy.md (§1 data collected, §3 where data lives, §4 retention, §6 consent, §10 sub-processors) and 03_Strategy/Compliance_Pack_PersonGraph_DRAFT_2026-07-05.md. Facts not established in those sources are marked [TO CONFIRM] — none invented.

0. Controller & governance identification

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II
DTI Business Name Registration	BN 8297508 · valid 25 Jun 2026 – 25 Jun 2031
Brand / trade name	Setnayan
Public domains	setnayan.com · setnayan.ph
Registered business address	[TO CONFIRM]
Total headcount / employees	[TO CONFIRM]
NPC registration number (if already registered)	[TO CONFIRM]
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com (registered with the NPC per policy §9)
DPO response SLA	7 business days (non-urgent); immediate for breach notifications
Breach notification	NPC + affected users within 72 hours of confirmation (policy §8)
Estimated data-subject counts (customers / vendors / guests)	[TO CONFIRM]

Shared infrastructure (applies across DPS's unless a row narrows it)

Layer	Provider	Location	Role
Web / application hosting	Vercel	[TO CONFIRM] (edge)	Processor
Primary database (PII + transactional)	Supabase / Postgres	Singapore	Processor · AES-256 at rest · RLS

Media (photos / video / face vectors)	Cloudflare R2	APAC / PH region	Processor · signed-URL access only
Transactional email	Resend	[TO CONFIRM] (US-based likely)	Processor
Vendor ID verification	Persona / Veriff / Onfido	US	Processor (batch-call, no ongoing storage)
AI text/contract analysis	Anthropic (Claude) · OpenAI (V1.5 fallback)	US	Processor · zero-retention API mode (Anthropic)
Music generation	Suno	[TO CONFIRM]	Processor — no PII processed

Cross-border baseline: routine operation crosses the SG↔PH border; encrypted in transit (TLS 1.3), governed by Cloudflare's and Supabase's PH-compliant DPAs, subject to NPC oversight (policy §10). US sub-processors are bound by Standard Contractual Clauses (SCCs) or equivalent (policy §10).

1. Records of Processing Activities — one record per Data Processing System

Legend — Legal basis per RA 10173 §12 (personal info) / §13 (sensitive personal info): **Contract** = §12(b) performance of contract; **Consent** = §12(a)/§13(a); **Legitimate interest** = §12(f); **Legal obligation** = §12(c)/§13(b)/§13(f). SPI = Sensitive Personal Information per RA 10173 §3(l).

DPS-01 · Customer / Couple Account & Event Planning

Field	Detail
Purpose	Provide the contracted planning platform: account, event setup, vendor matching (Guided + DIY), seating, save-the-date, in-app services
Legal basis	Contract (§12(b)) — service delivery; Consent (§12(a)) for marketing-sample opt-in (policy §6.2)
Data subjects	Customers (couples / organizers)
Personal data categories	Full name, mobile, email, optional profile photo; event data (date, venue, target pax, role); behavioral/in-app activity, Guided-mode decisions, search queries; uploaded content (Save-the-Date photos, invitation customizations)
SPI?	N (no SPI in the core account record)
Recipients / sub-processors	Supabase (DB), Vercel (hosting), Cloudflare R2 (content); Setnayan Team on mediation only
Cross-border transfer	SG (Supabase); APAC/PH (R2)
Retention	Account profile: active + 30-day grace on deletion, then purge. Event data: 5 years post-event, auto-purge T+5y; earlier on request (policy §4)

Security measures	AES-256 at rest; RLS per-user isolation; TLS 1.3; bcrypt passwords; optional 2FA; signed URLs for media
Risk level	Medium

DPS-02 · Vendor Account, Profile & Verification

Field	Detail
Purpose	Vendor onboarding, business profile, and the 12-document identity/business verification checklist (policy §3.4)
Legal basis	Contract (§12(b)); Legitimate interest (§12(f)) — DTI lookup, portfolio reverse-image, reference calls; Legal obligation (§13(f) / §12(c)) — AMLC sanctions/PEP screening per PH AMLA; Consent captured at registration
Data subjects	Vendors (business owners / primary representatives)
Personal data categories	Business identity (DTI Business Name Cert, BIR Form 2303, Mayor's Permit, business address, name+slug); service profile; financial (bank/e-wallet payout account, transaction history); behavioral (response times, conversion)
SPI?	Y — government-issued ID of the primary representative (RA 10173 §3(l) SPI); selfie + ID liveness video (biometric-adjacent). DTI/BIR/tax documents are legally-mandated records
Recipients / sub-processors	Persona / Veriff / Onfido (ID + liveness); AMLC API / ComplyAdvantage (sanctions/PEP); DTI Database (BN validation); Supabase; Cloudflare R2 bucket <code>setnayan-vendor-verification</code> (Verification Handler role only)
Cross-border transfer	US (Persona/Veriff/Onfido); UK (ComplyAdvantage); PH (AMLC, DTI); SG (Supabase); APAC/PH (R2)
Retention	Raw uploads (ID, selfie+liveness, bank micro-deposit, portfolio): 90 days hot, purged after approve/reject unless audit hold. Verification audit trail (Persona/AMLC results + admin rationale): 90 days hot + 7 years cold (BIR §235 + AMLC AML/CTF). DTI/BIR 2303/Mayor's Permit: 90 days hot + 7 years cold . Transaction history: 5 years (policy §4)
Security measures	Extra-restricted R2 bucket (single admin role); batch-call verification (no ongoing sub-processor storage); AES-256; RLS; audit log on all admin decisions
Risk level	High (SPI: gov ID + biometric liveness)

DPS-03 · Guest List & RSVP

Field	Detail
Purpose	Manage the couple's guest list, RSVP status, roles, table assignment, and special requests

Legal basis	Contract (§12(b)) — organizer's event service; Consent (§12(a)) for guest-provided data / photo consent at RSVP (policy §6.1)
Data subjects	Guests
Personal data categories	Full name, mobile, email, optional profile photo; event linkage + role (principal/secondary sponsor, family, friend), RSVP status, table assignment; behavioral (reels built, re-shares)
SPI?	Potentially Y — dietary restrictions / special-needs data collected at RSVP may reveal health or religious SPI (RA 10173 §3(l)). [TO CONFIRM] exact special-data fields captured in the RSVP schema
Recipients / sub-processors	Supabase; event organizer (couple); coordinator within join-permission scope
Cross-border transfer	SG (Supabase)
Retention	Aligned with event retention: 5 years post-event; deletion cascades on guest account deletion (subject to shared-gallery organizer-consent exception, policy §4)
Security measures	RLS event-scoping; TLS 1.3; guest opt-out toggles; AES-256
Risk level	Medium (High if dietary/health SPI confirmed)

DPS-04 · Face Vectors / Auto-Tagging (per-event, consented)

Field	Detail
Purpose	Auto-tag guests in an event's photo gallery via face matching (couple-scoped only)
Legal basis	Consent (§13(a)) — guest opts in by uploading RSVP profile photo for this purpose; revocable via "Delete my face data" / Photo Consent toggle (policy §6.1)
Data subjects	Guests
Personal data categories	128-dimension face vectors derived from RSVP photo + optional portal upload + on-the-day check-in kiosk
SPI?	Y — BIOMETRIC data (RA 10173 §3(l)). Highest-sensitivity category in the platform
Recipients / sub-processors	Cloudflare R2 per-event encrypted vector index; Supabase (linkage). No cross-border AI sub-processor for the vectors themselves [TO CONFIRM] (matching engine location)
Cross-border transfer	APAC/PH (R2 vector index)
Retention	Per-event lifetime + 5 years; auto-purge with event data. Guest revocation propagates within the next 5-minute refresh cycle (policy §1.4, §4)

Security measures	Per-event scoped — vectors never reused across events ; encrypted at rest; no cross-event face recognition (design lock, Person Graph DPIA #6); confidence-gated auto-tag
Risk level	High (biometric SPI)

DPS-05 · Papic / Photo & Video Capture & Delivery

Field	Detail
Purpose	Capture, store, tag, and deliver event photos/clips to couples and guests; Personal Reel rendering
Legal basis	Contract (§12(b)) — paid capture/delivery service; Consent (§6.1) for likeness/photo participation; opt-out → face-blur
Data subjects	Guests, customers (couples); incidental non-account attendees appearing in media
Personal data categories	Photos and video clips; likeness; capture metadata (captured_at, geo when available, device model, paired camera brand/model); tag associations
SPI?	N in the general case (images of persons are personal info, not per-se SPI), but images can incidentally reveal SPI (health, religion). Treat as elevated
Recipients / sub-processors	Cloudflare R2 (originals, signed-URL only); Supabase (tags/metadata); hierarchical read: organizer / coordinator / guest (tagged + global) / vendor (booking-relevant)
Cross-border transfer	APAC/PH (R2)
Retention	Originals: 90 days hot R2 + 5 years IA cold R2 (30-day-post-download compression rule + 5-year hard limit). Geo stripped on outbound shares; original on R2 retains it (policy §4, CLAUDE.md constraint)
Security measures	Signed URLs (5-min for sensitive media); no public reads; NSFW filter on-by-default (non-disableable); untagged-still-delivered; opt-out face-blur; couple review window before public unlock
Risk level	Medium–High

DPS-06 · Person Graph — Connections, Life Stories & Trusted-Circle (adults-only)

Field	Detail
Purpose	Durable person node; mutually-confirmed relationship connections; per-person life-story references; aggregate trusted-circle vendor signal (Person Graph pack)
Legal basis	Consent (§12(a)) — mutual, opt-in confirmation required for every edge; life stories rely on existing RSVP photo consent
Data subjects	Customers, guests (adults only — minors NOT processed)

Personal data categories	Person node (name, optional photo, events participated); first-degree connection edges (type + confirmed/pending state); life-story items = references (pointers), not copies ; trusted-circle signal = computed on read, not stored
SPI?	Potentially Y — relationship data can infer SPI (e.g., civil status, family/religious ties). Mitigated: extended kin derived not stored ; min-N ≥5 on aggregates
Recipients / sub-processors	Supabase (edges + references); no third-party sharing; connections never broadcast/browsable
Cross-border transfer	SG (Supabase)
Retention	Edges + references follow event/account retention (policy §4 / Compliance Pack §3); declined/hidden/opted-out suppressed immediately; reference dies with source media; trusted-circle not stored
Security measures	Mutual-confirmation gate; name-only + confirmed-only cross-person visibility; participant-scoped deny-by-default RLS; no "people you may know"; no cross-event face recognition ; DPIA completed (Compliance Pack §2, residual Low)
Risk level	Medium — Status: DRAFT, live behind flags; pending DPO/counsel sign-off. Minors/legacy (Phase 3) counsel-first, DPIA scoped-not-complete, not processed

DPS-07 · In-App Communications / Chat (0019)

Field	Detail
Purpose	Text chat between couples ↔ vendors ↔ coordinators; document/sheet/PDF/image sharing on threads
Legal basis	Contract (§12(b)) — coordination is core service
Data subjects	Customers, vendors, coordinators
Personal data categories	Chat message content; attached files (doc/sheet/PDF/image); pasted external meeting links (plain text). Vendor identity masked (company logo, not personal photo)
SPI?	N structurally, but free-text/attachments may contain SPI — treat as elevated
Recipients / sub-processors	Supabase Realtime (ephemeral) + Postgres (history); Cloudflare R2 thread-files bucket. Video meetings RETIRED 2026-05-16 — no video data stored
Cross-border transfer	SG (Supabase); APAC/PH (R2)
Retention	Messages: 5 years (aligned to event retention). Pasted meeting links follow parent message (policy §3.3, §4)
Security measures	RLS thread-scoping; per-thread coordinator join permission; vendor-identity masking; TLS 1.3; AES-256

Risk level	Medium
------------	--------

DPS-08 · Payments & Reconciliation (apply-then-pay)

Field	Detail
Purpose	Process PHP-direct service orders: BDO/GCash apply-then-pay, reference codes, manual reconciliation of proof-of-payment against orders
Legal basis	Contract (§12(b)); Legal obligation (§12(c)) — PH tax/BIR record retention
Data subjects	Customers, vendors
Personal data categories	Payment receipts, transaction references, partial bank/e-wallet details for receipts/refunds; payment-proof screenshots; reconciliation inbox messages. No complete card numbers, CVVs, or full bank account numbers stored
SPI?	N
Recipients / sub-processors	Supabase (payments, service_orders, payment_inbox_messages); Setnayan Team (manual reconciliation); Maya Business (V1.5+ gateway [TO CONFIRM] not active)
Cross-border transfer	SG (Supabase)
Retention	Transaction/receipt records: 5 years (tax compliance). Pending orders expire 7 days (policy §4, CLAUDE.md)
Security measures	No card/full-account storage; two-admin approval for refunds > ₱10K; append-only audit log; RLS; reference codes 8-char Crockford
Risk level	Medium

DPS-09 · In-App Behavioral / Product Analytics

Field	Detail
Purpose	Platform analytics for Setnayan admins (aggregated); platform improvement + ML model training (anonymized)
Legal basis	Legitimate interest (§12(f)) for aggregated operational analytics; Consent (§12(a)) for the secondary anonymized-training purpose (policy §2.1, §2.2)
Data subjects	Customers, vendors, guests
Personal data categories	In-app activity, surfaces visited, services purchased, vendor interactions, search queries, response/conversion metrics. Aggregated — never individually identified to admins outside dispute-mediation context
SPI?	N

Recipients / sub-processors	Supabase; PostHog [TO CONFIRM] (referenced in repo/iteration 0035; not named in this policy) — no PII per observability design
Cross-border transfer	SG (Supabase); PostHog host [TO CONFIRM]
Retention	Anonymized aggregate: indefinite (no PII). Underlying behavioral rows follow account/event retention (policy §4)
Security measures	Aggregation + de-identification for admin views; no PII in logs; opt-out toggle (per observability design) [TO CONFIRM]
Risk level	Low–Medium

DPS-10 · Email Notifications (Resend)

Field	Detail
Purpose	Transactional + milestone email: payment instructions/confirmation, refunds, vendor messages/status, RSVP received, wedding-day reminder, save-the-date, security alerts
Legal basis	Contract (§12(b)) for transactional mail; Consent (§12(a)) for promotional/marketing mail (revocable; RFC 8058 one-click unsubscribe)
Data subjects	Customers, vendors, guests
Personal data categories	Email address, recipient name, event/order context embedded in the message
SPI?	N
Recipients / sub-processors	Resend (delivery); SendGrid fallback [TO CONFIRM]
Cross-border transfer	US-based email provider likely [TO CONFIRM] (Resend jurisdiction)
Retention	Follows the underlying record; delivery logs [TO CONFIRM] retention at provider
Security measures	TLS in transit; one-click unsubscribe; RA 10173 + CAN-SPAM compliant templates
Risk level	Low

DPS-11 · Marketing Site / Cookies & Consent

Field	Detail
Purpose	Public marketing site (setnayan.com); analytics/consent management on public surfaces
Legal basis	Legitimate interest (§12(f)) for essential/first-party operation; Consent (§12(a)) for analytics/advertising cookies

Data subjects	Website visitors (prospective customers/vendors), guests
Personal data categories	Cookie/consent state, IP, user-agent (policy acceptance is logged with timestamp + IP + user-agent), first-party analytics identifiers
SPI?	N
Recipients / sub-processors	Vercel (hosting); analytics processor [TO CONFIRM]. Note: third-party display ads (AdSense) were RETIRED 2026-05-19 — no third-party ad cookies
Cross-border transfer	[TO CONFIRM] (edge/analytics host)
Retention	Consent state persistence [TO CONFIRM] (design referenced 12-month persistence); policy-acceptance log per user retained with account
Security measures	First-party cookie model; consent categories (essential / analytics / advertising); TLS 1.3; HSTS; CSP
Risk level	Low

DPS-12 · Anti-Fraud & Trust Integrity (identity clustering · fraud scoring · enforcement)

Field	Detail
Purpose	Protect marketplace trust signals from manipulation: cluster likely-same-person/household accounts by shared strong signals; de-duplicate vendor review/rating/booking stats per cluster with arm's-length exclusion; score per-vendor fraud anomalies; two-stage enforcement (reversible auto-suspend + human four-eyes wipe/ban). Spec 03_Strategy/Anti_Fraud_Trust_Integrity_2026-07-05.md
Legal basis	Legitimate interest (§12(f)) — fraud prevention / marketplace integrity. Requires a documented legitimate-interest balancing + disclosure (both outstanding — DPIA R-08 §6). Automated-suspension effect engages §16(c) (right to object) + §34 (automated processing) [TO CONFIRM] counsel
Data subjects	Couples / guests (whose device/address/payment signals are clustered — they never see cluster membership) + vendors (scored, and subject to auto-suspend / ban)
Personal data categories	Repurposed inputs (no new collection): device fingerprint (user_devices.device_hash), normalized home address (users.address_normalized), payment-sender identity (payments.reference_number→paying user). Derived: identity cluster_id; per-vendor fraud signals + 0–100 scores with non-PII evidence (counts/ratios/opaque labels); enforcement state + append-only audit. IP deliberately NOT captured
SPI?	N — inputs are personal information, not §3(l) SPI. Elevated because it is involuntary profiling with an automated decision that has a significant effect (vendor livelihood)

Recipients / sub-processors	Supabase (Postgres, Singapore) only — no third-party/AI sub-processor. Service-role / admin ONLY (REVOKE ALL FROM anon, authenticated + is_admin() RLS at CREATE); Setnayan admins via /admin/fraud + two-admin approval gate
Cross-border transfer	SG (Supabase)
Retention	identity_clusters / vendor_fraud_scores = recomputed matviews (no history). fraud_signals + fraud_enforcement_audit persist — explicit retention rule not yet defined [TO CONFIRM] . Signal inputs follow their source systems (device/address = account retention; payment = 5-yr tax, DPS-08)
Security measures	Service-role/admin-only + deny-by-default RLS at CREATE; non-PII evidence; reversible auto-suspend at high threshold (score ≥90); irreversible ban never automated — four-eyes gate + typed confirmation; append-only audit; help-center appeal path; AES-256; TLS 1.3
Risk level	High — Status: LIVE in production since 2026-07-07, ahead of counsel sign-off (owner-elected) . DPIA R-08 drafted (08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md); Privacy Policy Anti-Fraud disclosure + LIA + formal contest path outstanding

2. Threshold analysis — mandatory NPC registration

Under **RA 10173 and NPC Circular 17-01** (as amended), a PIC/PIP must register its DPS and DPO with the NPC when **any** of the following triggers is met. Assessment below.

#	Registration trigger (Circular 17-01 §4 / related issuances)	Setnayan assessment	Met?
1	Processing sensitive personal information of ≥ 1,000 individuals	Setnayan processes SPI: biometric face vectors (DPS-04), government ID + liveness for vendors (DPS-02), and potential health/religious data via RSVP dietary/special needs (DPS-03). Actual count [TO CONFIRM], but a weddings/events platform at scale is very likely to reach ≥1,000 SPI subjects	Likely YES
2	PIC/PIP with ≥ 250 employees	Sole proprietorship; headcount [TO CONFIRM] but almost certainly < 250	No (assumed)

3	Processing is likely to pose a risk to the rights and freedoms of data subjects	Yes — biometric processing, gov-ID + AML screening, guest likeness/media at scale, relationship graph, minors/legacy roadmap, and (DPS-12) involuntary identity-profiling with an automated decision that has a significant effect (auto-suspend/ban of a vendor's livelihood) . This is high-risk processing by nature	YES
4	Processing is not occasional (i.e., regular/systematic core-business processing)	Yes — data processing is the platform's core, continuous business function, not incidental	YES

Conclusion. Registration triggers **#1 (likely), #3, and #4 are met**. Trigger #2 is not (sole prop, sub-250 headcount). Under Circular 17-01 the criteria are **disjunctive** — meeting even one obligates registration, and Setnayan meets at least two independently (risk-to-rights + not-occasional), with the SPI-volume trigger also likely once counts are confirmed.

Recommendation: Setnayan should register its DPO and Data Processing Systems with the National Privacy Commission (NPC registration system), and appoint/confirm Indalecio Sacdalan Casasola II as the registered DPO. Registration is advisable on the risk-to-rights and not-occasional grounds alone; the SPI-volume trigger reinforces it. Confirm exact SPI data-subject counts [TO CONFIRM] and current NPC registration number [TO CONFIRM] before filing to determine whether this is an initial registration or an amendment.

3. Open items for DPO/counsel before filing

- [TO CONFIRM] Registered business address; headcount; SPI + total data-subject counts; existing NPC registration number.
- [TO CONFIRM] Exact RSVP special-data fields (dietary/health/religious) — determines whether DPS-03 is a formal SPI system.
- [TO CONFIRM] Jurisdictions/retention for Resend, PostHog (analytics), Vercel edge, Suno, and the face-matching engine host.
- [TO CONFIRM] Whether Maya Business (V1.5 payment gateway) is contracted; keep DPS-08 marked "not active" until then.
- DPS-06 (Person Graph) and the Person Graph amendment publish **only after** DPO/counsel sign-off; minors/legacy (Phase 3) require their own DPIA + NPC consultation before any build-to-live.

Draft compliance artifact prepared to a compliant baseline ahead of counsel. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel; this document is not a substitute for legal review and is not yet adopted for NPC filing.